



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Laundry Bear Zimbra Zero-Click Exploitation Campaign Threat Report

Threat Report

Classification	TLP:CLEAR
Published	2026-07-28
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | Laundry Bear Zimbra Zero-Click Exploitation Campaign Threat Report - Threat Report

Published: 2026-07-28 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Tactics, Techniques, and Procedures
7. Infrastructure and Indicators
8. Detection Engineering
 - 8.1. Detection Summary
 - 8.2. Hunt Query
9. Threat Hunting
 - 9.1. Hunt Hypothesis
 - 9.2. Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

Laundry Bear Zimbra Zero-Click Exploitation Campaign Threat Report

1. Executive Summary

Public reporting and government-advisory coverage in July 2026 describe Russian state-linked activity tracked as LAUNDRY BEAR exploiting a Zimbra webmail flaw to steal email and authentication recovery material from Western government and critical-infrastructure targets. Search-result summaries cite CISA/NSA and multiple partner agencies warning that the actor exploited a Zimbra zero-day before patching and continued targeting unpatched servers.

The defensive priority is straightforward: exposed Zimbra collaboration infrastructure should be patched, isolated, and reviewed for mailbox access, saved-password theft, and 2FA recovery-code exposure. Because the reported activity is espionage-oriented, email content, directory data, and long-lived authentication artifacts should be treated as likely objectives.

2. Intelligence Requirements

Question	Current Answer	Confidence
Who is associated?	LAUNDRY BEAR, also publicly linked in reporting to Void Blizzard / CL-STA-1114 / TA488 tracking.	Medium
What was targeted?	Zimbra webmail servers used by Western government and critical-infrastructure organizations.	Medium
What should defenders do first?	Patch Zimbra, review webmail logs, rotate exposed credentials/recovery codes, and hunt mailbox access anomalies.	High

3. Source Review & Confidence

Source	Contribution	Confidence
CISA / partner-advisory references in public reporting	Government warning and exploitation context.	Medium
BleepingComputer	Reports zero-day exploitation, Zimbra patch timing, and email theft focus.	Medium
CyberPress / secondary security reporting	Actor aliases and intelligence-objective context.	Low-Medium

4. Threat Activity Overview

The campaign reportedly used a Zimbra webmail vulnerability in a zero-click or low-interaction path to obtain mailbox data and authentication recovery material. Public reporting frames the campaign as intelligence collection rather than financially motivated extortion.

5. Affected Sectors and Exposure

Sector / Environment	Exposure Consideration
Government and public administration	Email and 2FA recovery data have high intelligence value.
Critical infrastructure operators	Webmail access can expose operations, vendor communications, and incident response coordination.

Managed or outsourced email environments	Third-party administrators may need coordinated log retrieval and patch validation.
--	---

6. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	Exploit public-facing application	Zimbra webmail zero-day/zero-click exploitation reported publicly.
Collection	Email collection	Reporting cites email theft and saved authentication material.
Credential Access	Credentials from webmail/recovery artifacts	Reporting cites saved passwords and 2FA recovery codes.

7. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
Zimbra webmail HTTP/S endpoints	Exposed service	Patch and log-review pivot.
Unusual mailbox export or access patterns	Behavioral indicator	Hunt for collection activity.
2FA recovery-code access	Account artifact	Credential-rotation trigger.

8. Detection Engineering

8.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
Unusual requests to Zimbra endpoints from rare ASNs/geographies	Web/proxy/WAF logs	Surface exploitation or reconnaissance.
Mailbox export, bulk download, or abnormal user-agent access	Zimbra/audit logs	Detect collection.
Post-exploit login from new IP after webmail anomaly	IdP / mail logs	Link exploitation to credential use.

8.2. Hunt Query

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ("/zimbra/", "/service/", "/h/", "/zimbraAdmin")
| summarize Hits=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName
| order by Hits desc
```

9. Threat Hunting

9.1. Hunt Hypothesis

If Zimbra exploitation occurred, mailbox access and account recovery artifacts may show unusual download/export activity shortly after suspicious web requests.

9.2. Hunt Query

```
SigninLogs
```

```

| where TimeGenerated > ago(30d)
| where AppDisplayName has_any ("Zimbra", "Mail", "Webmail") or ResourceDisplayName has_any ("Zimbra", "Mail", "Webmail")
| summarize Attempts=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), IPs=make_set(IPAddress, 20) by UserPrincipalName, AppDisplayName
| where array_length(IPs) > 3 or Attempts > 50

```

10. Risk Assessment

Likelihood is highest where Zimbra remains internet-facing and unpatched. Impact is high for government, critical infrastructure, and regulated organizations because mailbox access can expose plans, credentials, recovery codes, and partner communications.

11. Recommended Actions

Priority	Owner	Action
Critical	Messaging / infrastructure	Patch Zimbra and verify external exposure.
Critical	SOC	Review Zimbra HTTP, mailbox, and admin logs for exploitation and collection.
High	IAM	Rotate passwords, recovery codes, and session tokens for potentially exposed accounts.

12. References

- CISA/NSA partner advisory references cited in public reporting on LAUNDRY BEAR.
- BleepingComputer report on Zimbra zero-click exploitation.
- CyberPress report on LAUNDRY BEAR aliases and campaign focus.